

Clase 176 — OPSEC ofensiva

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Red Team Development and Operations (Vest & Tubberville)* 🕒 Duración estimada: **90 min** · Nivel: **Avanzado**

🎯 Objetivo

Interiorizar la seguridad operacional (OPSEC) del operador: el conjunto de hábitos y decisiones que evitan que la operación sea detectada, atribuida o quemada. El alumno aprenderá a razonar sobre la telemetría que genera cada acción, a elegir la técnica menos ruidosa que cumpla el objetivo y a llevar un registro operativo disciplinado.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Definir** OPSEC en el contexto de una operación ofensiva.
- 2. **Evaluar** el "footprint" de telemetría de una acción antes de ejecutarla.
- 3. **Elegir** entre alternativas por su relación sigilo/impacto.
- 4. **Aplicar** disciplina de infraestructura y logging del operador.
- 5. **Reaccionar** ante señales de que la operación fue detectada.

📖 Temas

#	Tema	Por qué importa
1	Concepto de OPSEC	Sigilo como disciplina, no como truco
2	Telemetría por acción	Todo deja rastro; hay que preverlo
3	Sleep/jitter y beaconing	Evitar patrones detectables
4	Elección de técnica	La menos ruidosa que cumpla el objetivo
5	Higiene de infraestructura	Separación, dominios, atribución
6	Logging del operador	Reproducibilidad y deconfliction
7	Detección y reacción	Qué hacer si te queman

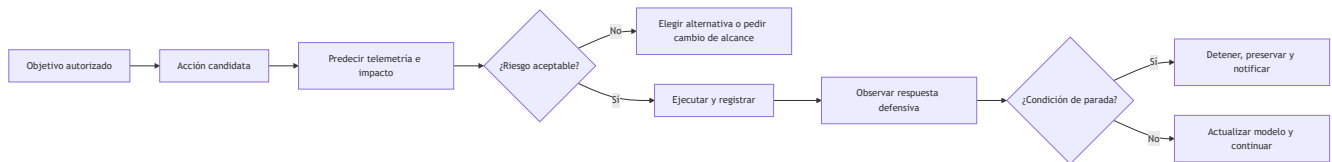
💡 Explicación en profundidad

OPSEC empieza por información crítica y amenazas

OPSEC no es una colección de trucos para «no dejar logs». Es un proceso de decisión: identificar qué información de la operación debe protegerse, observar qué indicadores podrían revelarla, analizar quién puede interpretarlos, valorar el riesgo y aplicar medidas proporcionadas. En un red team autorizado,

también protege al cliente: evita que la prueba cause daño, se confunda con un incidente real o exponga datos recogidos durante el ejercicio.

La paradoja esencial es que el operador necesita registrar con precisión lo que hace, aunque quiera reducir la huella en el objetivo. El registro se conserva en un canal controlado y con tiempo sincronizado. Así la white cell puede distinguir la prueba de actividad hostil y el equipo puede reconstruir resultados sin depender de memoria humana.



Menos periodicidad no significa ausencia de señal

El jitter modifica los intervalos de un beacon para reducir una periodicidad exacta. No oculta el destino, el volumen, el proceso, el patrón de sesión ni las características del protocolo. Un defensor puede analizar distribuciones temporales y contexto acumulado. La buena decisión es minimizar comunicaciones a las necesarias para cumplir el objetivo y comparar el canal con el tráfico normal autorizado, no aumentar aleatoriedad sin límite.

Cada acción se expresa como una pareja **efecto necesario / observaciones previsible**s. Si el objetivo es demostrar acceso a un archivo, quizá baste con leer un marcador inocuo; copiar un directorio completo agrega impacto y telemetría sin aumentar la evidencia. El sigilo profesional nace de la proporcionalidad.

Deconfliction y reacción ante una detección

Antes del ejercicio se acuerdan identificadores, contactos, canal de emergencia, ventanas y condiciones de parada. Cuando aparece una alerta inesperada, el operador no borra rastros ni improvisa. Registra el estado, reduce actividad y consulta a la white cell. Rotar infraestructura sin coordinación puede parecer una escalada real y privar al equipo azul de evidencia.

Si una técnica queda expuesta, la lección incluye **por qué**: proceso, red, identidad, contenido o secuencia. El informe no evalúa al operador por permanecer invisible a toda costa, sino por probar el objetivo con seguridad y mostrar qué controles observaron la actividad.

Definiciones y características

- **OPSEC**: proceso de proteger la operación evitando indicadores detectables o atribuibles. Característica: preventiva, se piensa antes de actuar.
- **Footprint / huella**: telemetría que una acción genera (procesos, red, logs). Característica: se estima por adelantado.
- **Beaconing**: patrón periódico de check-in del C2. Característica: detectable si no hay jitter suficiente.
- **Atribución**: capacidad del defensor de vincular la actividad a un origen. Característica: buena OPSEC la dificulta.
- **Deconfliction**: distinguir la actividad del ejercicio de un incidente real. Característica: requiere logging preciso del operador.
- **Burned (quemado)**: cuando una técnica/infra es detectada e inutilizada. Característica: obliga a rotar y adaptarse.

Glosario

- **OPSEC:** proceso para identificar y proteger información crítica frente a observación adversaria.
- **Información crítica:** dato cuya exposición perjudica la seguridad o validez del ejercicio.
- **Indicador observable:** señal que permite inferir una actividad o intención.
- **Huella:** conjunto de artefactos y telemetría generado por una acción.
- **Beacon:** comunicación periódica o semiperiódica de un agente con su infraestructura.
- **Jitter:** variación aplicada al intervalo de comunicación; no garantiza ocultación.
- **Deconfliction:** mecanismo para separar actividad del ejercicio de incidentes reales.
- **White cell:** autoridad que gobierna y conoce el ejercicio.
- **Condición de parada:** evento acordado que exige suspender o escalar actividad.
- **Registro del operador:** bitácora protegida con hora, activo, acción, resultado y responsable.
- **Proporcionalidad:** uso del menor impacto suficiente para demostrar el objetivo.

Herramientas y preparación

- El cuaderno de operación (repo/Obsidian) para registrar cada acción con hora, host, comando y resultado.
- La infraestructura C2 con redirectores y perfiles (Clases 164–165).
- Conocimiento de la telemetría defensiva (Sysmon, ETW, EDR) para anticiparla.
- Una matriz de "acción → telemetría → alternativa" como ayuda de decisión.

⚠ La OPSEC no es para "no ser atrapado haciendo algo ilegal": es para ejecutar un ejercicio autorizado de forma realista y medir la detección. Toda la práctica ocurre dentro del alcance y las RoE del engagement o en tu laboratorio.

Laboratorio guiado (ejercicio aplicado)

1. **Construye una matriz OPSEC.** Para 6 acciones (dump de LSASS, DCSync, escaneo, Kerberoasting, lateral por SMB, ejecución de PowerShell), anota la telemetría esperada y una alternativa más sigilosa.
2. **Analiza tu C2.** Revisa el sleep/jitter de tu implante y ajústalo para romper el beaconing; justifica el nuevo valor.
3. **Higiene de infraestructura.** Verifica que team server, redirectores y dominios están separados por función y sin datos que te atribuyan.
4. **Simula una acción ruidosa.** Ejecuta en el lab un dump de LSASS con Sysmon activo y observa el evento generado (EID 10); luego plantea cómo reducir esa huella.
5. **Registro disciplinado.** Documenta cada paso anterior en el cuaderno con timestamp, host y hash del artefacto, listo para deconfliction.
6. **Plan de reacción.** Escribe qué harías si detectas que el Blue Team te descubrió (rotar infra, bajar el ritmo, cambiar de canal).
7. **Revisión.** Contrasta tu matriz con lo observado en Sysmon y ajusta las alternativas.

Ejercicios

1. Define OPSEC con tus palabras y da un ejemplo de mala OPSEC.
2. Completa una matriz "acción → telemetría → alternativa" con 8 filas.

3. Explica cómo el jitter dificulta la detección de beaconing.
4. Diseña un esquema de infraestructura que minimice la atribución.
5. Redacta el formato de una entrada de cuaderno de operación.
6. Escribe un plan de 5 pasos para cuando te "quemar".

Reto verificable

Entrega una **matriz OPSEC** de al menos 8 acciones ofensivas con su telemetría y alternativa más sigilosa, respaldada por al menos una observación real en Sysmon de tu lab. **Criterio de aceptación:** cada fila tiene acción, telemetría concreta (evento/fuente de datos) y una alternativa justificada; al menos una fila se apoya en un evento que capturaste tú mismo en el laboratorio.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Detectado por beaconing regular	Jitter=0; añade variación al check-in
El Blue Team te atribuye rápido	Infraestructura reutilizada/identificable; sepárala e higienízala
No puedes hacer deconfliction	Sin cuaderno; registra cada acción con timestamp
Acción innecesariamente ruidosa	No evaluaste alternativas; usa la matriz antes de actuar
Persistes tras ser quemado	No rotaste; ten un plan de reacción listo

Preguntas frecuentes

 **¿OPSEC significa no ser detectado nunca?** No. Significa controlar cuándo y cómo generas telemetría, para no quemar la operación antes de tiempo y poder medir la detección de forma útil.

 **¿La técnica más sigilosa es siempre la mejor?** No; la mejor es la menos ruidosa que **cumple el objetivo**. Sigilo extremo que no logra la meta no sirve.

 **¿Por qué documentar tanto si busco sigilo?** El cuaderno es interno y esencial para deconfliction, reproducibilidad y el informe final. Sigilo ante el objetivo, transparencia total ante el cliente.

Referencias

- NIST — *Technical Guide to Information Security Testing and Assessment*, SP 800-115. <https://doi.org/10.6028/NIST.SP.800-115> — sustenta planificación, consideraciones legales, manejo de datos, ejecución segura y reporte.
- Vest & Tubberville — *Red Team Development and Operations*. <https://redteam.guide/> — marco específico para planificación, deconfliction y registro de operaciones red team.
- MITRE ATT&CK — *Defense Evasion* (TA0005). <https://attack.mitre.org/tactics/TA0005/> — taxonomía para describir técnicas; no se interpreta como garantía de invisibilidad.
- MITRE ATT&CK — *Application Layer Protocol* (T1071). <https://attack.mitre.org/techniques/T1071/> — referencia para relacionar comunicaciones C2 con fuentes de red y detección.
- Bryant, T. — *Operator Handbook* — consulta operativa complementaria; los límites del ejercicio se fundamentan en NIST SP 800-115.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 175 — Persistencia en Active Directory](#)



Siguiente clase

[Clase 177 — Red teaming físico](#)